

NetShieldAI™

Vulnerability Scan Report

ZAP Scanner

Automated web application security assessment, including risk-ranked issues and remediation guidance.

TARGET URL: http://example.com	SCAN DATE: 2026-01-05 11:50:29	REPORT GENERATED: 2026-01-05 11:50:29
-----------------------------------	-----------------------------------	--

Scan Overview

TOTAL ALERTS
5

HIGH RISK
None

MEDIUM & LOW RISK
2 Medium / 2 Low

Prioritize remediation of **High** and **Medium** risk findings first, then address Low and Informational issues as part of hardening.

Risk Level	Count
High	0
Medium	2
Low	2
Informational	1
Total	5

Risk & Score Legend

Badge	Meaning
High Risk	Issues that can lead to compromise of data, authentication, or full system control.
Medium Risk	Exposures that may enable privilege escalation or sensitive information leakage.
Low Risk	Minor weaknesses or best-practice deviations with limited impact.
Informational	Non-exploit issues that still provide useful security context.
Predicted Score	Model-based severity estimate based on vulnerability features and context.

Detailed Findings

Each card represents one ZAP alert. Use the Description and Solution sections to understand the impact and remediation steps. References may include external standards or documentation.

Missing Anti-clickjacking Header

Medium Risk

Predicted Score: 11.0

Confidence: Medium

URL: http://example.com

Description:

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Solution:

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Reference:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options>

Content Security Policy (CSP) Header Not Set

Medium Risk

Predicted Score: 5.25

Confidence: High

URL: http://example.com

Description:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Solution:

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Reference:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://www.w3.org/TR/CSP/>

<https://w3c.github.io/webappsec-csp/>

<https://web.dev/articles/csp>

<https://caniuse.com/#feat=contentsecuritypolicy>

<https://content-security-policy.com/>

X-Content-Type-Options Header Missing

Low Risk

Predicted Score: 5.25

Confidence: Medium

URL: http://example.com

Description:

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Solution:

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Reference:

[https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))

<https://owasp.org/www-community/Security-Headers>

ZAP is Out of Date

Low Risk

Predicted Score: N/A

Confidence: High

URL: <http://example.com>

Description:

The version of ZAP you are using to test your app is out of date and is no longer being updated.
The risk level is set based on how out of date your ZAP version is.

Solution:

Download the latest version of ZAP from <https://www.zaproxy.org/download/> and install it.

Reference:

<https://www.zaproxy.org/download/>

Predicted Score: N/A

Confidence: Medium

URL: http://example.com**Description:**

The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

Solution:

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

Reference:

<https://datatracker.ietf.org/doc/html/rfc7234>

<https://datatracker.ietf.org/doc/html/rfc7231>

<https://www.rfc-editor.org/rfc/rfc9110.html>